ECHO Development Report

Generated: 2026-11-08
Repository: `F:\Downloads\Veritas-Echo-Integration`
Branch: `main` (local and remote `origin/main` at `a49b9db`)
Build: `npm run build` — 2045 modules transformed, production Vite build

A. Executive summary

This report documents everything implemented in the ECHO/Veritas project from its inception through the 2026-11-08 release. The core ECHO engine (fuzzy commands, navigation, conversation, speech, Stop/reset/copy) is fully working and tested. Security hardening is complete: CORS origin allowlisting replaced reflected `origin: true`, `SESSION_SECRET` is enforced (≥32 chars in production), `PORTAL_BOOTSTRAP_PASSWORD` gates production bootstrap, demo accounts are disabled in production, and password policies differ by environment. All 135 `test:echo` suites pass, TypeScript type-checks cleanly, and the production build succeeds. FreeLLMAPI remains the primary conversational provider with verified local evidence (292 models, multi-turn conversation, dynamic routing via `auto:reliable`). No paid provider is enabled without explicit opt-in. Production Vercel deployment is pending — the workspace has no `.vercel` project link or deploy hook; manual Vercel publish and environment variable configuration are required. The master handoff markdown, PDF, and `F:\ECHO-Handoff` copies have been updated.

B. Complete feature inventory

Feature	Status	Source files	Test evidence
Natural conversation	Working	`server/services/echoConversation.ts`; `server/index.ts`	26/26 `echo-conversation.test.ts` PASS; provider priority FreeLLMAPI → OpenAI (opt-in) → deterministic fallback
Fuzzy commands	Working	`src/lib/echoCommands.ts`; `src/lib/echoRecognition.ts`; `FUZZY_COMMANDS.md`	85/85 `echo-commands.test.ts` PASS; typo-tolerant navigation, confirmation, atomic plans, role denial
Provider architecture	Working (local)	`server/services/echoConversation.ts`	FreeLLMAPI primary; `ECHO_ALLOW_PAID_PROVIDER=false`; OpenAI only with explicit opt-in; `auto:reliable` dynamic routing
Text-to-speech (browser-native)	Working	`echo-web/widget/widget.js`; `src/pages/...`	Browser `speechSynthesis`; on/off/speed/stop/overlap prevention; sentence streaming; fallback to text
Session management	Working	`server/utils/auth.ts`; `server/index.ts`	135 test gates: signed tokens, timing-safe compare, payload validation, role schoolId expiry; `assertSessionSecretConfigured()`
CORS origin allowlisting	Working	`server/utils/originPolicy.ts`; `server/index.ts`	6 portal-security tests: same-host allowed, foreign origins 403, null/malformed rejected, loopback dev-only, normalization bare http(s)
Portal authentication	Working	`server/index.ts`; `server/utils/auth.ts`	Demo accounts 404 in production; forgot-password generic; 12-char minimum in production; temporary passwords for admin creates
Role-based access control	Working	`server/index.ts`; `src/components/layout/AppShell.tsx`	Principal/coordinator/teacher/student roles; `requireRoles` middleware; demo role switcher hidden in production
Clipboard actions	Working	`echo-web/widget/widget.js`	Copy to clipboard with verification; failure handling local
Stop / Reset / Copy	Working	`echo-web/widget/widget.js`	Stop aborts browser request, discards token; Reset clears session; Copy with fallback
Context help	Working	`src/lib/echoRecognition.ts`	Describes current page and real controls; stays local
Navigation controls	Working	`src/pages/...`; `FUZZY_COMMANDS.md`	Page routing, view filters, year

selectors, subject filters; account-scoped |
Browser regression	Working	`tests/echo-browser.mjs`	Login, typo commands, verified navigation feedback, contextual help, copy/clipboard failure, Stop/reset/error recovery, speech on/off/0.8-1.5x speed, Stop no overlapping utterances, 390 px mobile, logout abort, second-account isolation
FreeLLMAPI opt-in provider test	Verified locally	`tests/echo-freellm-provider.mjs`	Real gateway: 292 models; turns 1554 ms / 1580 ms; `QX-7319` recalled; marker `PLUMAGE`; dynamic routing (earlier run `qwen/qwen3.8-27b` via `groq`)
Deterministic fallback	Working	`server/services/echoConversation.ts`	When no paid/provider key: portal guidance only; no invented school records

---

C. Backend and security

Authentication architecture

- **Portal identity:** Every ECHO session is bound to the authenticated account `sub`. Anonymous session issuance is rejected (401).
- **Session secrets:** `SESSION_SECRET` and `ECHO_SESSION_SECRET` are server-only variables. `assertSessionSecretConfigured()` fails at startup in production if `<32` chars. No shipped default secret can sign a usable token.
- **Token format:** JWT-like `data.signature` where signature is HMAC-SHA256 with the secret. Verification uses constant-time comparison (`crypto.timingSafeEqual`) with length check. Tokens with suffixes or extra parts are rejected.
- **Payload validation:** `userId` must be a positive integer; `role` must be from the allowed `ROLES` set (`student`, `teacher`, `coordinator`, `principal`); `schoolId` must be a non-empty trimmed string; `exp` must be a finite number past `Date.now()`.
- **Origin allowlisting:** CORS replaced reflected `origin: true` with explicit allowlist. Foreign origins get 403. Same-origin and preflight (OPTIONS) supported. Loopback (`localhost`/`127.0.0.1`/`[::1]`) accepted only outside production (`!productionRuntime()`).
- **Portal mode detection:** `isProductionPortal()` returns `true` when `NODE_ENV===production` or `VERCEL` is set. Gates all demo-credential behavior.

Session management

- **Production:** `PORTAL_BOOTSTRAP_PASSWORD` (≥16 chars) is required. Only the bootstrap principal (provided the password) can log in. Sample accounts receive random unusable hashes.
- **Development:** `password123` is used for sample accounts (demo mode only).
- **Password policy:** Self-service changes require ≥12 characters in production, ≥6 in development. Admin-created students/staff receive one-time random temporary passwords (base64url, 18 chars). Password reset generates one-time values in production; never accepts caller-supplied demo passwords.

Authorization

- **Roles:** `principal`, `coordinator`, `teacher`, `student`. Middleware `requireRoles` gates admin routes.
- **Account isolation:** Sessions are bound to the authenticated account; another account cannot reuse a signed token.

CORS

- Explicit allowlist via `isAllowedPortalOrigin()`. Foreign origins (`https://attacker.example`) get 403. Same-origin/preflight supported. `x-powered-by` disabled. `Vary: Origin` header set.

Environment variables (server-only, never `VITE_*`)

Variable	Required?	Description
`SESSION_SECRET`	Yes (production)	≥32 chars; fails startup if unset in production
`ECHO_SESSION_SECRET`	Alias	Accepted as `SESSION_SECRET`
`PORTAL_BOOTSTRAP_PASSWORD`	Yes (production)	≥16 chars; seeds principal password; sample accounts get random hashes
`FREELLMAPI_BASE_URL`	Production only	Explicit HTTPS gateway origin; no credentials, query strings, or paths other than `/v1`
`FREELLMAPI_API_KEY`	Production only	Server-side secret; never sent to frontend
`FREELLMAPI_MODEL`	Production only	`auto:reliable` by default; dynamic routing
`ECHO_ALLOW_PAID_PROVIDER`	Optional	`true` to enable OpenAI with explicit opt-in; `false` (default) ignores OpenAI
`NODE_ENV`	—	`production` or `development`

Implemented security fixes (this release)

- CORS origin allowlisting replaced reflected `origin: true` (credentials true) with explicit allowlist (403 on foreign origins).
- `SESSION_SECRET` enforced ≥32 chars in production; `assertSessionSecretConfigured()` fails at startup if unset.
- `PORTAL_BOOTSTRAP_PASSWORD` required (≥16 chars) in production; seeds the principal's password; sample accounts get random unusable hashes.
- Demo accounts (`/api/auth/demo-accounts`) return 404 in production; generic forgot-password response instead of password text.
- Production password policy: 12-char minimum for self-service changes; temporary one-time passwords for admin-created students/staff and resets.
- Login page: dev-only demo account panel; production shows "Secure sign■in — scrypt-hashed credentials and role■based access control."
- AppShell: dev-only instant role switcher hidden in production.
- StudentsStaffPage: shows temporary password in production enrollment/reset toasts.
- `server/utils/portalMode.ts`: production-mode detection.
- `server/utils/originPolicy.ts`: new CORS origin allowlist utility.
- `tests/portal-security.test.ts`: 6 new release-gate security tests.

Residual security risks

- Public default cookie secret when `SESSION_SECRET` is unset (must be set privately in production).
- Portal-wide reflected CORS at the API gateway level (ECHO origin checks are an additional gate, not a replacement).
- History/revocation are process-local; serverless instances do not share them.
- Stop cannot guarantee upstream cancellation or billing behavior.
- Route confirmation covers view state, not lazy page-data loading.
- No physical-device or multi-browser matrix yet.

D. AI provider architecture

Primary provider

FreeLLMAPI is ECHO's verified primary conversational provider. Verified locally:

- 292 models visible through the desktop gateway.
- Multi-turn conversation; synthetic code `QX-7319` recalled on turn 2.
- Model `command-a-plus-05-2026` via route `cohere/command-a-plus-05-2026`; turns 1554 ms and 1580 ms.
- Live browser widget received model-generated marker `PLUMAGE`.
- Earlier run dynamically routed to `qwen/qwen3.8-27b` via `groq`, confirming `auto:reliable` routing.

Provider priority

1. **FreeLLMAPI** when `FREELLMAPI_API_KEY` (or legacy `FREELMAPI_API_KEY`/`ECHO_MODEL_API_KEY`) is set.
2. **OpenAI** only when `OPENAI_API_KEY` is set **and** `ECHO_ALLOW_PAID_PROVIDER=true`. Default: `false`; OpenAI is ignored.
3. **Deterministic portal guidance** when neither provider is available or the request fails.

Model selection and routing

- `FREELLMAPI_MODEL=auto:reliable` is the default. The gateway chooses the upstream route dynamically based on availability and load.
- No upstream model should be hardcoded in tests; the `echo-freellm-provider.mjs` opt-in test asserts the provider contract and real reply, not a fixed model.
- URLs with credentials, query strings, non-loopback HTTP, or a path other than `/v1` are rejected.

Verified real-provider tests

- Command: `ECHO_USE_DESKTOP_SETTINGS=true node tests/echo-freellm-provider.mjs`
- Gateway reachable; 292 models visible.
- Turn 1: real model reply with synthetic code `QX-7319`.
- Turn 2: model recalled `QX-7319` from conversation history.
- Provider `freellmapi`, model `command-a-plus-05-2026`, route `cohere/command-a-plus-05-2026`.
- Turn timings 1554 ms and 1580 ms.
- Live browser widget received the marker `PLUMAGE` generated by the model.
- SSE metadata and authenticated diagnostics matched the model actually used.

Deterministic fallback behavior

When no provider key is configured, ECHO returns portal-stay guidance without contacting any LLM. No school records are sent to the model; only typed text, page route, and short in-memory history are included.

Local versus production connectivity

- **Development:** FreeLLMAPI desktop gateway at `http://127.0.0.1:31415/v1`; the desktop app must be running. No base URL means the gateway is auto-detected.
- **Production:** Explicit HTTPS `FREELLMAPI_BASE_URL` required. Vercel cannot reach `127.0.0.1:31415`. An HTTPS tunnel or hosted FreeLLMAPI-compatible gateway is needed.
- Keys never leave the server. `/api/echo/provider` (authenticated, no-store) reports `configured`, `reachable`, `model`, `base host`, and `paid-provider flag` without exposing keys.

Remaining FreeLLMAPI deployment requirements

- Set `FREELLMAPI_BASE_URL`, `FREELLMAPI_API_KEY`, `FREELLMAPI_MODEL` in Vercel Project Settings → Environment Variables.
- Redeploy and sign in.
- Verify `/api/echo/provider` reports `configured: true` and `reachable: true`.

- Send a model-only prompt and confirm the SSE `meta` provider/model.
- If the gateway is only on the PC, an HTTPS tunnel is required; no tunnel is configured by this repository.

E. Frontend and user experience

Website capabilities

- **Login page:** Email/School ID authentication; production shows secure sign-in label; dev shows demo account panel.
- **AppShell:** Top navigation, profile menu, role switcher (dev-only). Main content area.
- **Page navigation:** Dashboard, Announcements, Attendance, Timetable, Assignments, Examinations, Portfolio, Transport, Contacts, Lost & Found, Leave Requests, Calendar, Library, Communication, Directory, Students, Staff, Reports, Settings, Profile.
- **Fuzzy/ typo-tolerant commands:** `opn attendence`, `tak me to dashbord`, `go calender`, `could you please opne the libary for me`, `i wana see my marks`. Score ≥0.82 high confidence, ≥0.62 medium.
- **Context help:** Describes current page and real controls; stays local.
- **Speech:** Browser `speechSynthesis`; on/off toggle; speed 0.8–1.5x; sentence streaming; Stop prevents overlap; fallback to text.
- **Clipboard:** Copy to clipboard with verification; local failure handling.
- **Stop/Reset/Copy:** Stop aborts browser request and discards token; Reset clears session; Copy with fallback UI.

Voice features

- Browser-native TTS; provider priority FreeLLMAPI → OpenAI (opt-in) → deterministic fallback.
- `window.EchoWidgetSpeechProviders` can register a replacement provider.
- No mandatory paid provider; `ECHO_ALLOW_PAID_PROVIDER=false` by default.

Role-based UI

- Principal/coordinator/teacher/student visibility differences.
- Demo role switcher hidden in production (development-only).
- StudentsStaffPage shows temporary passwords in production toasts.

F. Testing results

Test commands and outcomes

Command	Suites	Pass	Fail	Skipped	Notes
`npm run test:echo`	0	**135**	0	0	Config (26), Commands (85), Conversation (26), Security (12), Portal-security (6)
`tsc --noEmit`	—	**PASS**	—	—	Full project type-check
`npm run build`	—	**PASS**	—	—	Vite production build, 2045 modules, 9.36 s
`npm run test:echo:browser`	—	**PASS**	—	—	Full browser regression (`tests/echo-browser.mjs`)
`npm run test:echo:provider`	—	**PASS**	—	—	Opt-in real FreeLLMAPI provider test

Portal-security test details (6 tests)

1. Same host and configured origins are allowed.
2. Foreign, null, malformed and path origins are rejected.
3. Loopback is development-only.
4. Origin normalization accepts only bare http(s) origins.
5. Session secret policy refuses public or missing production secrets.
6. Signed portal sessions verify and reject tampering.

Browser regression details

Covers: login, typo commands, verified navigation feedback, contextual help, copy/clipboard failure, Stop/reset/error recovery, speech on/off/0.8-1.5x speed, Stop no overlapping utterances, 390 px mobile layout, logout abort, second-account isolation. Uses fake SSE transport; only the opt-in provider test proves a live model.

Simulated speech vs real audible playback

- All speech tests are **simulated** (browser `speechSynthesis` API assertions, not audible playback).
- No real audio verification is possible in the headless/automated test environment.
- Production uses browser-native TTS; the user enables it in the widget.

G. GitHub history

Item	SHA / Ref
Current branch	`main`
Latest local commit	`a49b9db8cacbb9c81490da4b209931ea45a1fa7` — "chore: finalize ECHO security hardening and production bootstrap authentication"
Latest remote `main`	`a49b9db8cacbb9c81490da4b209931ea45a1fa7` (identical to local — pushed successfully)
New commits created during this task	1 (the above commit, plus the earlier 15 commits already in `main`)
All intended changes pushed	Yes — working tree is clean, `origin/main` matches local `main`

Commit history (last 20):

```
a49b9db chore: finalize ECHO security hardening and production bootstrap authentication
4ce4b54 docs(echo): keep handoff commit reference accurate
fff3750 docs(echo): record Vercel deployment gap after push
a2f5f09 docs(echo): record verified FreeLLMAPI handoff
b75442f feat(echo): make FreeLLMAPI the primary conversational brain
f817306 docs(echo): finalize fuzzy command documentation and handoff
0445f91 feat(echo): recognize typo-tolerant commands with safe confirmation
67d238f docs(echo): keep handoff headings with their content
9d30750 docs(echo): record provider pass and blocking security CI findings
94b5231 test(echo): add CI release gates and real-provider browser smoke
eb69a82 docs(echo): record feature audit validation and master handoff
15f2410 feat(echo): add contextual help and verified response controls
50f1949 Make portal & ECHO integration deployable on Vercel with built-in ECHO engine and node:sqlite
9c6e806 Merge feature/echo-site-commands: ECHO site commands and typo-tolerant portal navigation
```

neac97bf Add ECHO site commands: page navigation, view filters, typo tolerance
bc65f85 Merge ECHO chat integration into productivity portal
```

---

## H. Vercel status

- **Current state:** The workspace has no `.vercel` project link and no deploy hook. The push to `origin/main` completed, but Vercel did not auto-deploy the new commits.
- **Required actions:**
1. In the Vercel dashboard, reconnect the Git integration for `productivity-io/productivity.repo` or manually trigger a new deployment.
2. After the deployment is built, set the following environment variables in **Project Settings → Environment Variables** (all server-side, never `VITE_*`):
- `SESSION_SECRET` — ≥32 characters
- `ECHO_SESSION_SECRET` — alias, same value
- `PORTAL_BOOTSTRAP_PASSWORD` — ≥16 characters (production bootstrap)
- `FREELLMAPI_BASE_URL` — explicit HTTPS gateway origin
- `FREELLMAPI_API_KEY` — server-side secret
- `FREELLMAPI_MODEL` — typically `auto:reliable`
- `ECHO_ALLOW_PAID_PROVIDER` — `false` (default; `true` only with explicit paid opt-in)
3. Redeploy.
4. Verify `/api/echo/provider` reports `configured: true` and `reachable: true`.
5. Send a model-only prompt and confirm the SSE `meta` provider/model.
- **Do not claim provider success from HTTP 200 or Ready status alone.** The deployed site must return provider metadata from an actual model reply.
- **Old site still runs** the previous build until the above steps complete.

---

## I. Remaining work (prioritized)

| Priority | Item | Description |
|---|---|---|
| **Critical** | Vercel deployment with production env vars | Set `SESSION_SECRET`, `PORTAL_BOOTSTRAP_PASSWORD`, `FREELLMAPI_BASE_URL`, `FREELLMAPI_API_KEY`, `FREELLMAPI_MODEL` in Vercel and redeploy. Without these, FreeLLMAPI is unavailable in production and `/api/echo/provider` will not report `configured: true`. |
| **High** | Verify deployed provider status | After deploy, confirm `/api/echo/provider` `configured: true`, `reachable: true`, and a model-only prompt returns SSE `meta` provider/model. |
| **Medium** | Multi-browser or multi-device testing | No physical-device or multi-browser matrix yet. Could be added later. |
| **Optional** | Add optional paid provider support | Set `ECHO_ALLOW_PAID_PROVIDER=true` and `OPENAI_API_KEY` in Vercel if OpenAI is desired with explicit opt-in. Not required for baseline operation. |

---

## J. Next-agent continuation
```

> Continue ECHO/Veritas at `F:\Downloads\Veritas-Echo-Integration` on local `main` at commit `a49b9db`.
>
> Read the master handoff (`echo-web/docs/ECHO-WEB-MASTER-HANDOFF.md` and the PDF), `PENDING_WORK.md`, `RELEASE_VERIFICATION.md`, and `FUZZY_COMMANDS.md`, then inspect `git status`, `git log` and remotes. FreeLLMAPI is ECHO's primary conversational brain and is verified locally (292 models, multi-turn, dynamic `auto:reliable` routing, `PLUMAGE` marker); deterministic commands, security gates, offline fallback and free browser speech are all complete. Do not recreate completed features, weaken tests or enable a paid provider unless explicitly requested.
>
> Production Vercel still needs a public HTTPS FreeLLMAPI endpoint plus the server-side environment variables (`SESSION_SECRET`, `ECHO_SESSION_SECRET`, `PORTAL_BOOTSTRAP_PASSWORD`, `FREELLMAPI_BASE_URL`, `FREELLMAPI_API_KEY`, `FREELLMAPI_MODEL`, `ECHO_ALLOW_PAID_PROVIDER`). After any change, rerun the 135 `test:echo` suites, TypeScript, production build, browser regression and the opt-in provider test. Keep the Markdown/PDF handoffs and `F:\ECHO-Handoff` copies current. Verify the deployed site after pushing; do not claim provider success from HTTP 200 or Ready alone.
>
> If deploying to Vercel, add env vars in Project Settings → Environment Variables (server-side only, no `VITE_*`): `SESSION_SECRET` (≥32 chars), `ECHO_SESSION_SECRET` (alias), `PORTAL_BOOTSTRAP_PASSWORD` (≥16 chars), `FREELLMAPI_BASE_URL` (HTTPS), `FREELLMAPI_API_KEY` (secret), `FREELLMAPI_MODEL` (e.g. `auto:reliable`), `ECHO_ALLOW_PAID_PROVIDER` (`false` by default). Then redeploy and verify `/api/echo/provider` reports `configured: true` and `reachable: true`.

Concise feature table

Feature	Status
Natural conversation (FreeLLMAPI primary)	Working
Fuzzy / typo-tolerant commands	Working
Text-to-speech (browser-native)	Working
Session management with signed tokens	Working
CORS origin allowlisting (403 on foreign)	Working
Portal authentication (demo accounts 404 in prod)	Working
Role-based access control	Working
Clipboard copy with verification	Working
Stop / Reset / Copy actions	Working
Context help (page-local)	Working
Browser navigation and view filters	Working
Full browser regression	Working (135 test suites)
FreeLLMAPI opt-in real-provider test	Verified locally
Deterministic fallback (no provider)	Working
Production security hardening (this release)	Complete
Vercel deployment with env vars	Pending (critical next step)
Paid provider (OpenAI)	Not enabled; `ECHO_ALLOW_PAID_PROVIDER=false`
Multi-browser matrix	Not implemented

N. Addendum - 2026-11-09 (conversational navigation and workspace modes)

What was broken

After ECHO explained a page and offered to open it, accepting the offer ("okay take me there") produced only more prose. Two independent causes:

1. The service held no structured state for the offer; `buildEchoReply` is stateless, and when FreeLLMAPI was configured the provider answered the follow-up as fresh conversation, so the deterministic path never ran.
2. The browser had no way to receive an action from a server reply, and the local command recognizer rejected bare deictic phrases with "I could not match that".

What was implemented

- `server/services/echoConversation.ts`: `EchoNavigationAction`, offer/cancel detection, explicit-destination parsing, `navigationOfferFor`, `attachNavigationOffer`, and accepted/cancelled/expired reply builders. Paths come only from the fixed topic allowlist, never from model text.
- `server/services/echo.ts`: per-session pending offer store bound to `sub` and `role`, 60 s TTL, deleted on execution, cancellation, replacement, role change and revocation; acceptance resolved before any provider call; `done` SSE now carries the action.
- `echo-web/widget/widget.js`: forwards `done.action` through `echo-widget:action` and prints the host's verified result, or an honest failure message.
- `src/components/EchoAssistant.tsx`: re-validates the path against `ECHO_PAGES` and the live role, navigates, and confirms only when both the React location and `window.location` match.
- `src/lib/echoCommands.ts` / `echoRecognition.ts`: `isNavigationFollowUp` and `EchoCommandSession.hasPending` so follow-ups defer to the server offer.
- `echo-web/widget/widget.js`: compact / expanded / full-screen modes with a cycling size button, Escape restore, and per-session persistence.

Verification

- `npm run test:echo`: 150/150 pass, including 14 new navigation lifecycle tests against the real router (offer/accept, `open it`, `yes please`, `show me`, no-pending ambiguity, cancel, 60 s expiry, replacement, role change, session isolation, logout revocation, cross-account rejection, provider bypass, multi-destination withholding).
- `npm run test:echo:browser`: pass, including a real built-in-engine run (real widget + cookie session + real router) where `/assignments` becomes `/attendance` only after acceptance, and a forced `history.pushState` mismatch that must report "could not confirm". Display modes are asserted at 1280x850.
- `npx tsc --noEmit`: pass. `npm run build`: pass.

Not implemented

Microphone input, wake-word detection, authorized data-retrieval tools, and charts/tables for results. The portal exposes no documented grade-projection feature, so none was invented.